

Command Y Argument Injection

Solo para laboratorios autorizados. Sustituye variables, confirma versión y guarda salida.

Decisión rápida

1. Confirma alcance, identidad y conectividad.
2. Parte de una señal; no ejecutes toda la tabla.
3. Predice salida y prepara un control negativo.
4. Ejecuta la prueba menos intrusiva.
5. Registra evidencia y vuelve al módulo si falla.

Señales

- Un parametro que hace de host/IP/dominio para una operacion de red (ping, traceroute, whois).
- Un campo de nombre de fichero usado para convertir, comprimir o procesar con una herramienta externa.
- La salida incluye trazas de una herramienta concreta (barra de progreso de curl, 'Resolving host...' de wget).
- Los separadores de shell no ejecutan comandos, pero cambiar la URL/fichero si altera el resultado.

Comandos y pruebas

Prueba	Objetivo/contexto	Evidencia esperada
<code>curl -sS -X POST "\$URL/api/ping" -H 'Content-Type: application/json' -d '{"host":"127.0.0.1; id"}'</code>	Prueba de confirmacion inocua: si 'host' llega a un ping del sistema, el ; encadena tu comando id sin romper el ping original.	La salida de id (uid=www-data...) mezclada en la respuesta confirma ejecucion. El usuario que veas es con el que tendras shell tras escalar.
<code>http://127.7</code> <code>file:///etc/passwd</code>	curl acepta varias URLs en una invocacion; el espacio separa un segundo argumento y file:// es un esquema local. La primera URL supera la validacion superficial y la segunda lee el fichero.	El contenido de /etc/passwd en la respuesta. Confirma inyeccion de argumentos/URL en curl (no command injection): la lectura ocurre por el esquema file://, no por un shell.

Diagnóstico

Síntoma	Comprobar
Sin respuesta	ruta, DNS, puerto, listener y firewall
Rechazo	sintaxis, credenciales, permisos y versión
Salida distinta	control negativo, caché y estado
Resultado parcial	identidad efectiva y precondiciones

Cierre

- Guardar comando adaptado y salida.
- Anotar qué confirma y qué no.
- No persistir secretos en notas compartidas.
- Restaurar cambios del laboratorio.

Fuente operativa: conceptos de Fieldbook. Método: construcción de payloads.